

A2A-Token-System

面向多 Agent 协作的零信任授权平台

陈奕燊

组长 · IdP / OPA

周展鹏

Gateway / Web / Audit

金梓墨

Agents / SDK / 飞书

杭州电子科技大学 · 飞书 AI 校园挑战赛 决赛 2026

github.com/your-org/A2A-Token-System

核心代码模块速览

IdP

/token/exchange

三验签发委托 token · 按需最小权限

Gateway

authn_middleware

唯一入口 JWKS 验签 + per-call
OPA 复核

OPA

agent.authz / a2a.rego

Rego 10 条全 AND · 决策与代码
解耦

Audit API

BatchWriter

asyncio.Queue → SQLite 批写
+ SSE 广播

SDK

client.invoke

屏蔽 DPoP + TE · 三框架
adapter

doc_assistant

dispatcher._topo_layers

LangGraph DAG 拓扑分层并发
执行

data_agent /

web_agent

tool dispatcher

飞书 OpenAPI + Tavily 检索

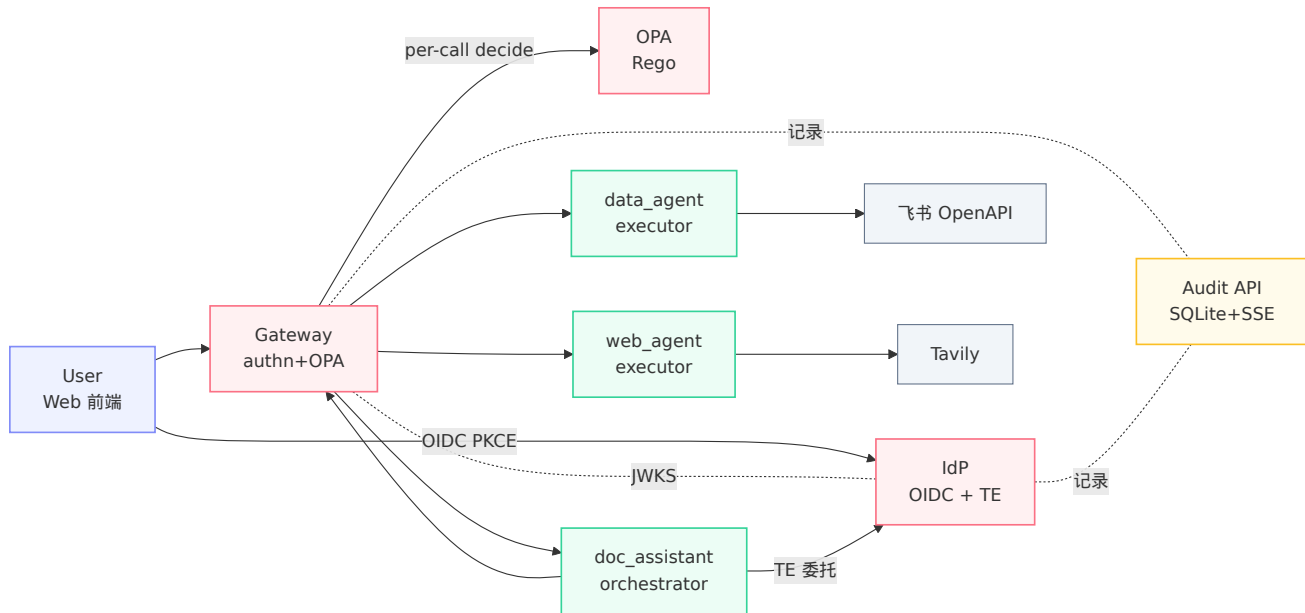
Web 前端

OIDC PKCE

RFC 7636 抗授权码截获

下一页看 7 模块如何协同 →

系统架构



标准协议栈 (OIDC + Token Exchange + DPOP) · 职责严格分离 (orchestrator / executor 互斥)

系统功能简述

①

用户登录

OIDC + PKCE (RFC 7636)

抗授权码截获

一次性 code → access_token

②

Token Exchange

RFC 8693 委托链

客户端 assertion + DPoP + 上游 token

120s 一次性 · one_time 强制

③

执行鉴权

Gateway 验签 + per-call OPA

Rego 全 AND 决策

Audit 全程记录

□ **AI 链路** (编排 / 调用 / 输出) 与 **安全链路** (IdP / GW / OPA) **严格隔离** — AI 故障不污染授权决策

Agents 实现：编排者 + 执行者

doc_assistant

orchestrator

- LangGraph DAG 编排
- `planner` : LLM JSON mode + 规则回退
- `_topo_layers` 拓扑分层
- `asyncio.gather` 同层并发
- `validate_dag()` 失败重试

data_agent

executor

- Intent 路由 (regex 匹配)
- 飞书 OpenAPI : bitable / docx / contact / calendar / drive
- Prompt Injection 清洗
- 无 LLM · 纯确定性

web_agent

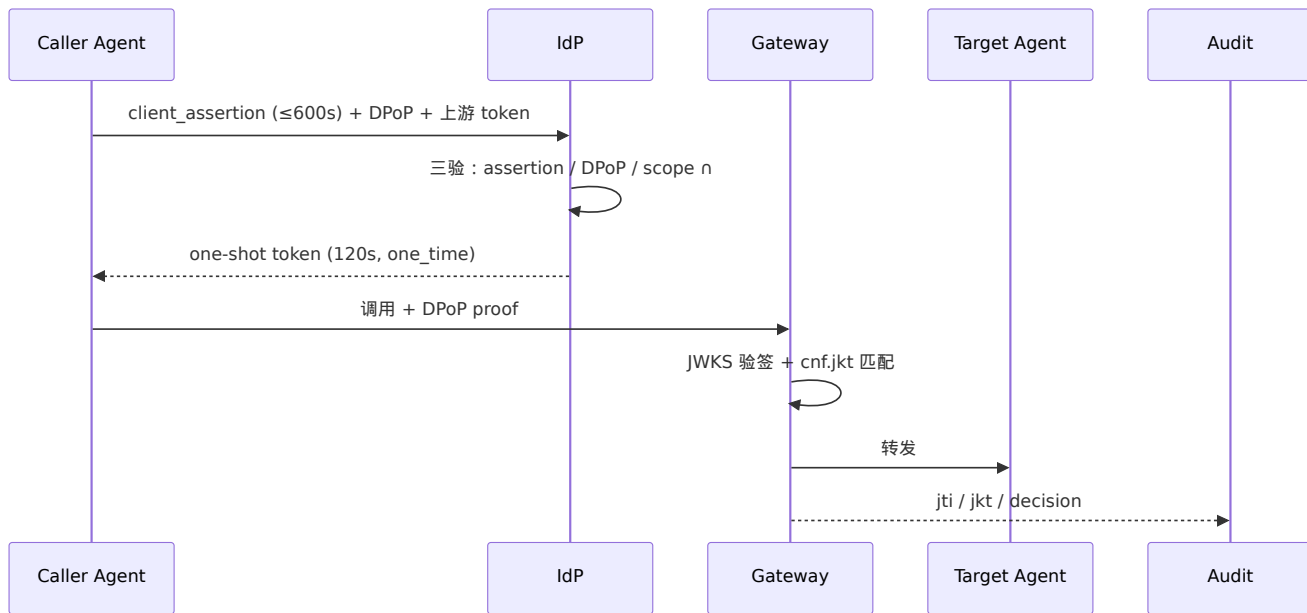
executor

- `web.search` · Tavily 检索
- `web.fetch` · HTML 提取 + LLM 摘要
- URL allowlist 限制
- 速率限制 + 安全提取

共享基础设施

- **SDK** : 屏蔽 RFC 8693 TE + RFC 9449 DPoP + W3C traceparent
- `@field_validator("role")` 强制 orchestrator / executor 互斥
- **AgentServer** 基类 · `capability.find()` 调用前匹配
- 三框架 adapter : LangChain · LangGraph · AutoGen

亮点 ①：标准协议栈 + 零信任 A2A



assertion 证身份

one-shot token 防重放

DPoP 防盗用

亮点 ②：最小权限 + 三道关

最小权限计算

```
effective_scope =  
  callee_caps ∩  
  user_perms ∩  
  requested_scope
```

- **callee_caps**：被调端能力上限（注册时声明）
- **user_perms**：用户授权范围（OIDC consent）
- **requested_scope**：本次任务真正需要

三者全空 ⇒ 拒签 · 永不"宽给"

三道关防御

① IdP 签发关

事前 ABAC：subject / agent / action / context

② Gateway × OPA 关

per-call Rego 10 条全 AND 复核

③ Capability 匹配关

启动期注册声明 + 调用前 `capability.find()` 二次校验

亮点 ③：撤销 · 职责 · 审计 · 生态

6 维即时撤销

```

revocation_sets = {
  "jti": "单 token",
  "sub": "用户级",
  "agent": "Agent 级",
  "trace": "调用链",
  "plan": "任务计划",
  "chain": "委托链",
}
# Redis Pub/Sub → 全集群秒级生效

```

职责严格分离

- `role = orchestrator` 只能编排
- `role = executor` 只能执行
- `field_validator` 注册时强制
- 互斥防止越权升级

完整审计链

- W3C **traceparent** header 全链传播
- 字段：decision / reasons / jti / jkt / scope / sub
- SQLite WAL 持久化 + SSE 实时推送
- 多维查询：按用户 / Agent / 链路

与生态正交

- **OPA** 复用（不重造策略引擎）
- Adapter：**LangChain** / **LangGraph** / **AutoGen**
- 标准协议栈 — 任何框架可接入
- **77 SDK 测试**（100% pass）

AI 亮点：功能侧 + 工程侧

□ 功能侧（产品中的 AI）

① 结构化 DAG 编排

Schema 校验不合规直接拒，杜绝幻觉跑偏

② JSON Mode + 后置 Schema 校验

LLM 输出经 `validate_dag()` 双重防线，不合规 LLM 重试

③ AI 与安全完全隔离

AI 路径无授权决策权 — 故障不污染安全

④ 用户描述目标即完成

DAG 自动拓扑分层并发 — 多源任务一句话搞定

□ 工程侧（开发中的 AI）

① 需求 → 方案

AI 头脑风暴备选 → 人工拍板

② 架构 → 设计文档

AI 写 spec 作为编码"合同"

③ 编码 Plan-Act

先出 plan 拆任务，再 Act 执行

④ 测试与审计

AI 定位根因 → 人工确认提交

Runtime: **Doubao Seed 2.0 Pro** (agents LLM 调用) · 开发协作: Claude (spec/plan/code review)

项目背景及落地价值

△ **痛点**：AI Agent 需以用户身份操作企业数据，OAuth 缺乏机器代机器细粒度授权

① 解决权限失控

120s 一次性委托 + sub_jti 绑定
根本消除横向渗透与凭据外溢

② 可信协作链路

每次委托一条完整记录
全链 traceparent 追责到 Agent

③ 满足合规审计

不可篡改日志 + 多维查询
对接等保 / SOC2 / 内部审计

④ 业务效率

用户描述目标即完成 · AI/安全不妥协
通用扩展：换框架不换授权

相关产品调研

方案	定位	与本项目差异
draft-aap-oauth-profile	IETF 组合规范	草案 · 无开源实现 · 细节实现不同
permit.io	决策判定 (PDP)	不解决 token 委托 · 权限模型不同
Okta for AI Agents	闭源 SaaS	强绑定 Okta 平台 · 国内合规风险
Veto	单 Agent 策略	单 Agent 视角 · 不做 A2A 委托
Portkey Agent Gateway	LLM 流量代理	只记录不裁决 · 无授权能力
OPA	通用策略引擎	直接复用，不重造

差异化定位：标准协议栈 + 零信任 + 最小权限 + 全链审计 + 多框架 adapter — 五位一体

Thank You

期待你的提问

陈奕燊 · 组长

IdP / OPA / 早期 AuditApi

周展鹏

Gateway / Web 前端 / Audit 测试

金梓墨

Agents 架构 / SDK / 飞书接入

github.com/your-org/A2A-Token-System

关键数字：120s 委托 · 6 维撤销 · 3 道关 · 6 RFC · 77 SDK 测试 100% pass